

تمرین جلسه یازدهم

تمرین اول – تست مالکیت داده با دو کاربر

دو کاربر مختلف بسازید.

مثلاً:

ali

sara

با کاربر اول وارد شوید و حداقل ۱ MoodEntry ثبت کنید.

سپس Logout کنید یا Session کاربر را عوض کنید و با کاربر دوم وارد شوید و ۱ MoodEntry متفاوت ثبت کنید.

بعد وارد صفحه Report شوید.

نتیجه مورد انتظار

کاربر اول فقط MoodEntry های خودش را ببیند.

کاربر دوم هم فقط MoodEntry های خودش را ببیند.

در پایان پاسخ دهید:

1. چه خطی از Query باعث می شود هر کاربر فقط داده های خودش را ببیند؟
2. اگر این Filter حذف شود چه اتفاقی می افتد؟
3. چرا این موضوع فقط یک Bug معمولی نیست و به امنیت و Privacy هم مربوط می شود؟

تمرین دوم – بررسی مالکیت هنگام ذخیره

در فرم ثبت Mood فیلد **user** نباید توسط خود کاربر انتخاب شود.

بررسی کنید چرا این Field داخل MoodEntryForm نمایش داده نمی‌شود.

بعد این بخش کد را با دقت بررسی کنید:

```
(entry = form.save(commit=False
```

```
entry.user = request.user
```

```
)entry.save
```

با زبان خودتان توضیح دهید هر خط چه کاری انجام می‌دهد.

سؤال مهم

اگر مستقیماً این را بنویسیم:

```
()form.save
```

ولی **user** یک Field اجباری باشد، چه مشکلی ممکن است ایجاد شود؟

چالش اضافه تر اول – اطلاعات کاربر را در صفحه نمایش دهید

در **base.html** یا یکی از صفحات اصلی، وضعیت Login کاربر را نمایش دهید.

مثلاً اگر User وارد شده بود:

Welcome ali

یا:

Logged in as: ali

اگر User وارد نشده بود، یک پیام متفاوت نشان دهید.

برای این قسمت بررسی کنید Template به اطلاعات User فعلی چگونه دسترسی دارد.

چالش اضافه تر دوم – Logout را کشف کنید

در کلاس دیدیم که تلاش برای Logout با درخواست GET ممکن است با خطا مواجه شود.

این بار بررسی کنید چگونه می‌توان Logout را با درخواست POST انجام داد.

راهنمایی

به این نکات فکر کنید:

- Logout قرار است باعث تغییر وضعیت کاربر شود.
- قبلاً برای ارسال POST از `<form>` استفاده کردیم.
- Request از نوع POST به CSRF Token نیاز دارد.

سعی کنید به جای یک لینک ساده مثل:

```
<a href="#">Logout</a>
```

از یک Form کوچک استفاده کنید.

ساختار کلی را خودتان پیدا کنید.

بعد بررسی کنید:

1. چرا Logout با POST منطقی‌تر از GET است؟
2. چرا در Form مربوط به Logout به CSRF Token نیاز داریم؟
3. بعد از Logout مقدار `request.user` چه تغییری می‌کند؟